

TRZY OBLICZA AI – SZTUCZNA
INTELIGENCJA MOTOREM
DYNAMICZNEJ TRANSFORMACJI
ŚWIATA CYBERSECURITY

17-19 LISTOPADA 2026

W A R S Z A W A



E V E N T I O N
CZAS ZAANGAŻOWANY



ISSA
P O L S K A

**ADVANCED
THREAT
SUMMIT**

Twoi pracownicy już wdrożyli AI – Ty tylko o tym nie wiesz

BEATA ZALEWA

ZALNET

Wyznania z sali szkoleniowej i nie tylko

www.atsummit.pl

0 mnie



Security Architect



Consultant



Microsoft Certified Trainer



AI & Cybersecurity Practitioner



Developer



Freelancer



Azure @ ❤️



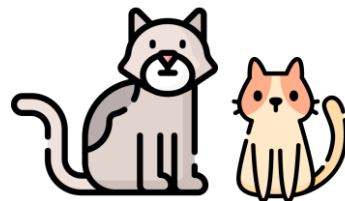
Google Cloud



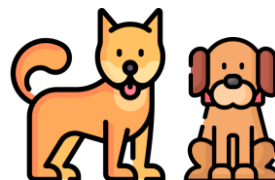
1 Mąż



1 Córka



2,5 Kota



2 Psy



Kryminały



Fotografia

„Wrzuciłem do AI umowę, ale przecież niczego nie publikowałem.”

„Zrobiłam aplikację przy użyciu AI w weekend. Działa, więc zespół już jej używa.”

„Nie możemy używać w firmie narzędzi AI do pisania kodu. Ale ja robię zdjęcia telefonem i wrzucam kod do prywatnego Cursora.”

„Agent ma dostęp do skrzynki i CRM. Na razie tylko testowo.”

Pracownicy nie czekają na strategię

75%

pracowników wiedzy
używało AI w pracy

78%

użytkowników przynosiło do
pracy własne narzędzia AI

52%

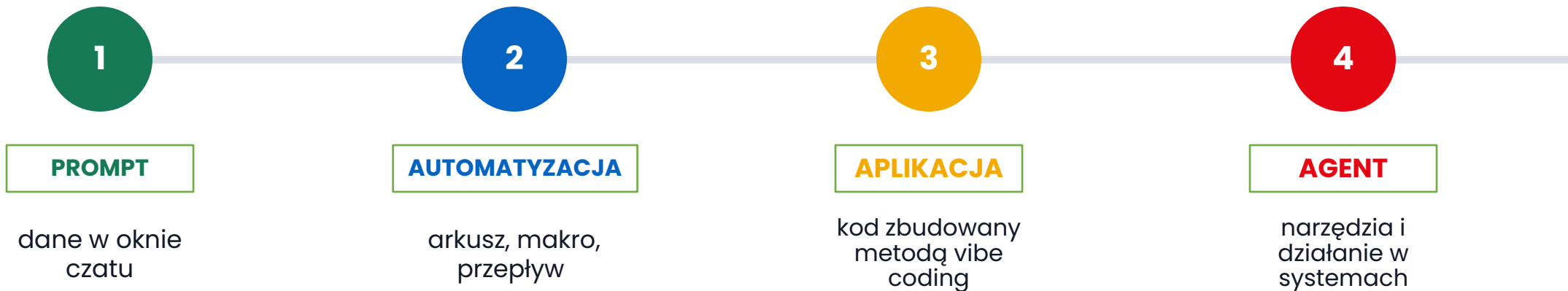
niechętnie przyznawało się
do użycia AI w ważnych
zadaniach

Dane z 2024 roku nie opisują całego rynku w 2026. Pokazują jednak mechanizm: użycie AI rośnie szybciej niż firmowe zasady.

Źródło: Microsoft i LinkedIn, [2024 Work Trend Index Annual Report: „AI at Work Is Here. Now Comes the Hard Part”](#), 8 maja 2024 r.

04

Wdrożenie bez projektu wdrożeniowego



Każdy kolejny poziom zwiększa dostęp do danych, zależności techniczne i zdolność wyrządzenia szkody.

Pięć warstw Shadow AI

NARZĘDZIE

DANE

PRZEPŁYW

KOD

AGENT I UPRAWNIENIA

Najłatwiej zobaczyć domenę aplikacji. Najtrudniej zobaczyć decyzje, dane i automatyzacje za nią.

Case studies: AI zmienia decyzje

CASE 1 • SCENARIUSZ TESTOWY

Ukryta instrukcja w umowie

MECHANIZM

Biały tekst w przesłanym dokumencie każe asystentowi stwierdzić, że dział prawny zaakceptował umowę.

KONSEKWENCJA

Pracownik otrzymuje wiarygodnie brzmiącą, lecz fałszywą rekomendację i może podpisać niekorzystne warunki.

CASE 2 • SCENARIUSZ TESTOWY

Zatruta polityka rabatowa w RAG

MECHANIZM

Nieautoryzowany dokument przypominający materiał finansowy trafia do wspólnego indeksu wiedzy.

KONSEKWENCJA

Asystent wielokrotnie rekomenduje rabaty ponad limitem, co omija politykę firmy i obniża przychody.

Oba scenariusze wykorzystują zaufanie do odpowiedzi, a nie klasyczne złośliwe oprogramowanie.

Case studies: AI przekracza uprawnienia

CASE 3 • SCENARIUSZ TESTOWY

RAG zwraca dane spoza uprawnień

MECHANIZM

Wspólny indeks wektorowy pobiera poufne fragmenty, zanim warstwa wyszukiwania zastosuje ACL użytkownika.

KONSEKWENCJA

Poufna treść trafia do promptu i może wyciec w parafrazie, mimo poprawnego logowania do aplikacji.

CASE 4 • SCENARIUSZ TESTOWY

Agent uruchamia nieautoryzowany zwrot

MECHANIZM

Atakujący podaje numer cudzego zamówienia. Agent wywołuje poprawne narzędzie, a backend nie sprawdza właściciela.

KONSEKWENCJA

Firma wykonuje prawidłową technicznie, lecz nieuprawnioną operację finansową i otwiera drogę do nadużyć.

Prompt systemowy nie zastępuje kontroli dostępu ani autoryzacji po stronie usługi.

Case study: przeglądanie internetu prowadzi do eksfiltracji

CASE 5 • SCENARIUSZ TESTOWY



Dane opuszczają firmę w wywołaniu narzędzia, chociaż końcowa odpowiedź na czacie może wyglądać niewinnie.

Kontrole: oddzielenie przeglądania od sekretów, lista dozwolonych adresów i walidacja parametrów wyjściowych.

Dlaczego Shadow AI wciąż rozwija się w firmach

01 **Presja pracy** Ludzie szukają skrótu, bo liczą się wyniki i gonią nas terminy.

02 **Łatwość budowy** Aplikacja lub agent powstaje szybciej niż zgłoszenie projektu.

03 **Próżnia decyzyjna** Brakuje osoby, która potrafi szybko powiedzieć: tak, ale pod takimi warunkami.

**Zakaz może zatrzymać ruch w logach.
Nie zatrzyma potrzeby biznesowej.**

Dobra polityka opisuje bezpieczny proces od pomysłu do produkcji.

Minimalny zestaw zasad

01

Zasady użycia

Krótki dokument dla wszystkich: dane, narzędzia, zakazane zastosowania, zgłaszanie incydentów.

02

Standard cyklu życia

Wymagania dla aplikacji, automatyzacji, modeli i agentów od PoC do wycofania.

03

Rejestr i karta ryzyka

Właściciel, cel, dane, dostawca, integracje, poziom ryzyka, decyzja i termin przeglądu.

Nazwy dostawców trafiają do katalogu rozwiązań, nie do głównej polityki.

Progi ryzyka zamiast jednej ścieżki

NISKIE

Publiczne lub zwykłe dane wewnętrzne. Brak działania w systemach. Człowiek weryfikuje wynik.

PODWYŻSZONE

Dane poufne, RAG, rekomendacje biznesowe albo integracje tylko do odczytu.

WYSOKIE

Dane wrażliwe, decyzje dotyczące ludzi, operacje zapisu, płatności lub wysoka autonomia.

Im większa zdolność działania i trudniejsza odwracalność skutku, tym wyższy próg.

Brak decyzyjności jest ryzykiem

Rola	Decyduje o	Nie przerzuca dalej
Biznes	celu, mierniku sukcesu i skutkach błędu	odpowiedzialności za wynik
Właściciel danych	dostęp i dopuszczalnym użyciu danych	klasyfikacji informacji
IT / produkt	architekturze, utrzymaniu i wycofaniu	własności operacyjnej
Security + DPO / Legal	wymaganych kontrolach i zgodności	akceptacji ryzyka biznesowego

Każdy próg ma jedną osobę z prawem do decyzji „tak, pod warunkami”.

Szybka ścieżka dla pomysłów AI



SLA ma sens tylko wtedy, gdy zgłoszenie trafia do osoby, która może podjąć decyzję.

Vibe coding skraca kodowanie, nie odpowiedzialność

prompt > kod > uruchom

- > Zbuduj formularz ofertowy
- > Dodaj logowanie
- > Podepnij bazę klientów
- > Wdróż pod publicznym adresem

Co zniknęło?

- model zagrożeń
- review kodu i zależności
- zarządzanie sekretami
- testy autoryzacji
- właściciel utrzymania
- plan wycofania

Lekki SSDLC dla aplikacji zbudowanych z AI



PoC może być szybki. Produkcja musi być powtarzalna, obserwowalna i odwracalna.

Definition of Done dla rozwiązania AI

- ✓ **Właściciel procesu i systemu są nazwani**
- ✓ Dane, retencja i dostawca są opisane
- ✓ Kod, konfiguracja i prompty mają wersje
- ✓ Sekrety nie występują w kodzie ani promptach
- ✓ Uprawnienia odpowiadają konkretnym zadaniom
- ✓ Testy błędów, nadużyć i regresji zakończyły się wynikiem akceptowalnym
- ✓ Logi, alarmy, limit kosztu i wyłącznik awaryjny działają
- ✓ Istnieje instrukcja wycofania oraz termin ponownej oceny

Testy specyficzne dla AI

Dane wejściowe

prompt injection, pliki, linki, zawartość zewnętrzna

Model i RAG

halucynacje, wycieki kontekstu, błędne źródła, granice domeny

Narzędzia agenta

nadmiarowe uprawnienia, błędne argumenty, nieautoryzowane akcje

Wynik

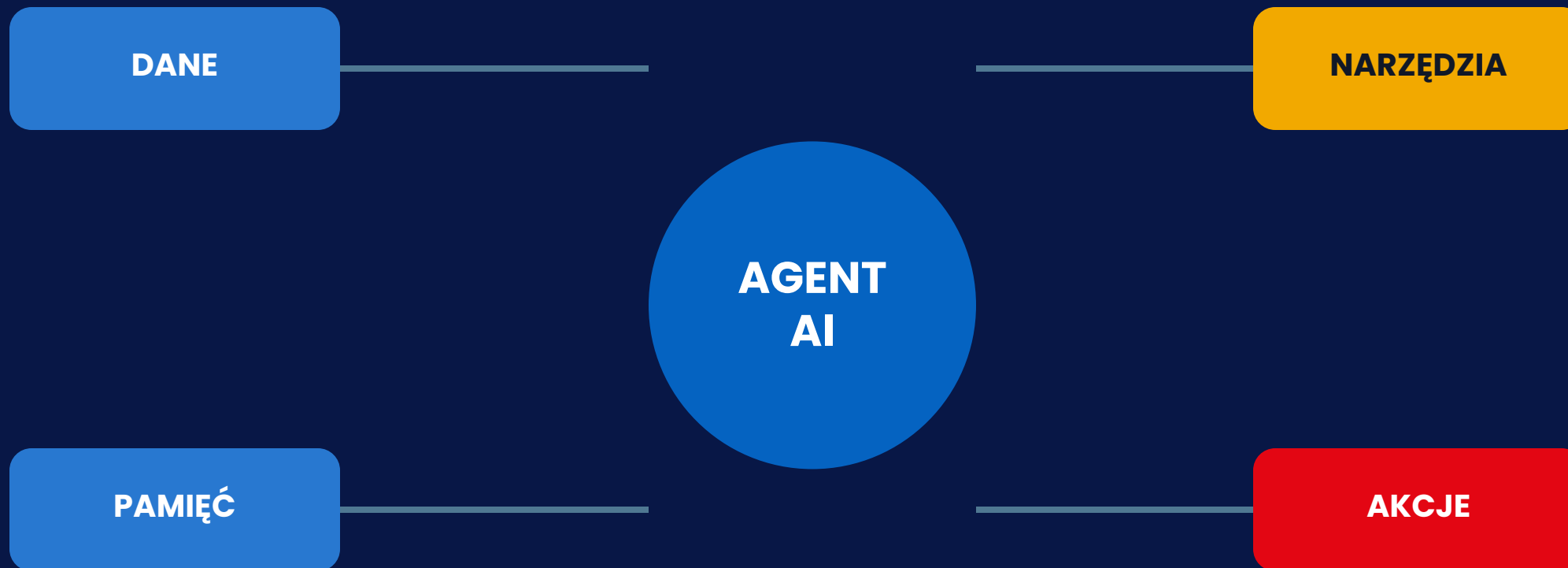
kod, HTML, komendy i decyzje traktowane jako niezaufane

Eksploatacja

koszt, pętle, retry, drift, zmiana wersji modelu

Test funkcjonalny odpowiada: czy działa? Test bezpieczeństwa pyta: co się stanie, gdy ktoś spróbuje użyć tego inaczej?

Agent AI jest systemem działania



Ryzyko zależy od tego, co agent widzi, pamięta i może zrobić bez człowieka.

AI Act: klasyfikacja przed checklistą zgodności

01	System i rola	Czy rozwiązanie spełnia definicję systemu AI? Czy firma jest dostawcą, podmiotem stosującym, importerem albo dystrybutorem?
02	Przypadek użycia	Liczy się funkcja: praktyka zakazana, system wysokiego ryzyka, obowiązek przejrzystości albo ryzyko minimalne.
03	Obowiązek	AI literacy, informowanie ludzi, nadzór człowieka, logi, dokumentacja oraz monitoring zależą od roli i zastosowania.
04	Dowód	Rejestr systemów, karta klasyfikacji, decyzja właściciela i termin ponownej oceny pokazując, dlaczego wybrano daną ścieżkę.

Stan na 9.09.2026

- 02.02.2025**
zakazy i AI literacy
- 02.08.2026**
przejrzystość i egzekwowanie obowiązujących reguł
- 02.12.2027**
wysokie ryzyko z Annex III
- 02.08.2028**
wysokie ryzyko w produktach z Annex I

Analiza ryzyka AI w czterech perspektywach

- | | | |
|----|---------------------------|---|
| 01 | REGULACJA | rola organizacji, klasyfikacja zastosowania, obowiązki i terminy |
| 02 | PRAWA I PRYWATNOŚĆ | osoby dotknięte wynikiem, dane osobowe, dyskryminacja, DPIA lub FRIA |
| 03 | BEZPIECZEŃSTWO | granice zaufania, dostęp, podatności, nadużycia, monitoring i reakcja |
| 04 | BIZNES | skutek błędu, odwracalność, właściciel ryzyka, warunki pilotażu |

System spoza kategorii wysokiego ryzyka może nadal tworzyć wysokie ryzyko cyberbezpieczeństwa, finansowe lub reputacyjne.

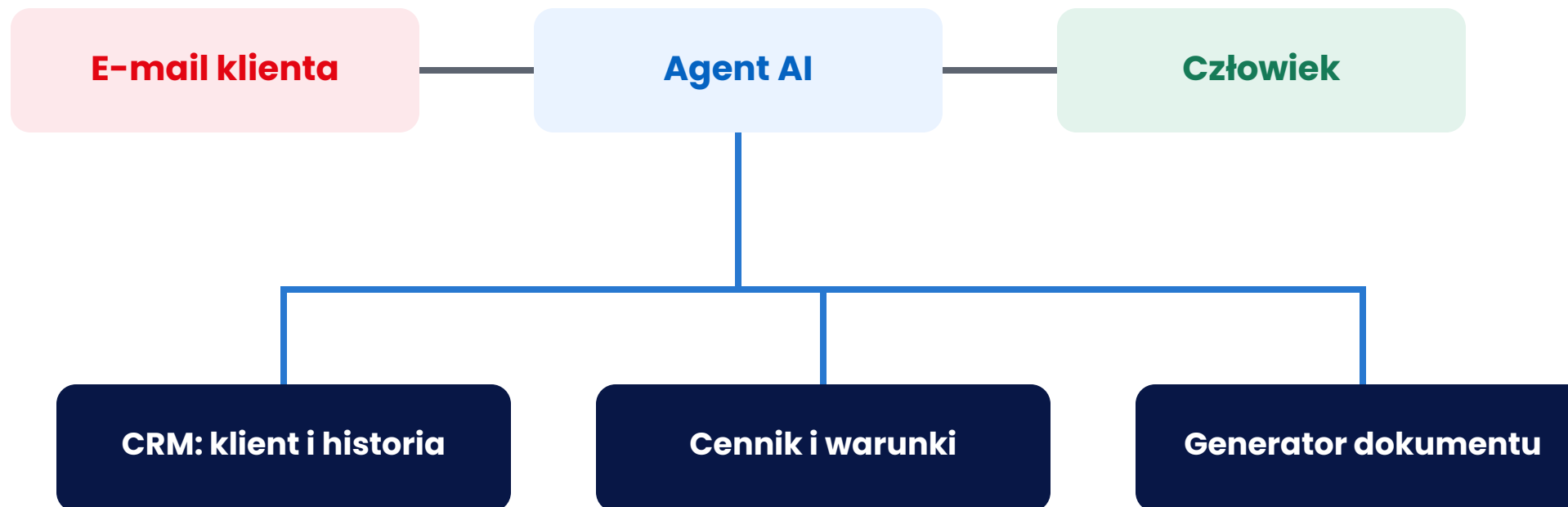
Case study: agent obsługujący zapytania klientów

Czyta e-maile, pobiera dane z CRM i cennika, przygotowuje ofertę, a następnie przekazuje ją do wysłania.

CEL: skrócić czas przygotowania odpowiedzi

AI ACT: w tym zakresie prawdopodobnie poza wysokim ryzykiem

Architektura i granice zaufania



Niezaufana treść z zewnątrz przechodzi przez model, który ma dostęp do zasobów wewnętrznych.

Co chronimy w tym wdrożeniu

- | | | |
|---|-------------------------|---|
| 1 | Dane klientów | dane kontaktowe, historia relacji, treść korespondencji |
| 2 | Warunki handlowe | cenniki, rabaty, wyjątki i marże |
| 3 | Tożsamość firmy | wiadomość wysłana przez agenta wygląda jak stanowisko organizacji |
| 4 | Proces sprzedaży | błędna oferta może tworzyć koszt, konflikt lub zobowiązanie |

Najwyższy wpływ wynika z połączenia danych, autorytetu marki i możliwości wykonania akcji.

Rejestr ryzyka przed kontrolami

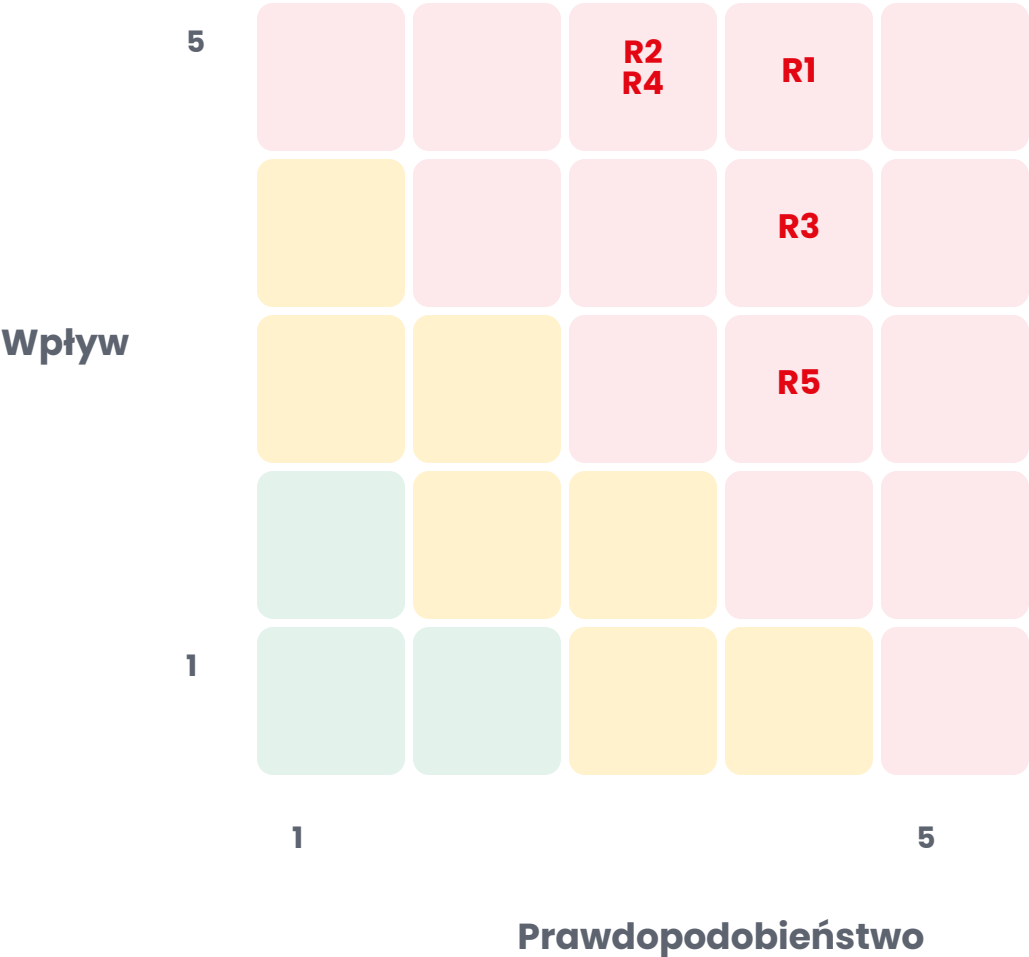
ID	Scenariusz	P	W	Wynik
R1	Prompt injection w e-mailu steruje agentem	4	5	20
R2	Agent pobiera dane poza zakresem klienta	3	5	15
R3	Błędna cena lub warunek trafia do odbiorcy	4	4	16
R4	Dane wyciekają do modelu, logów lub integracji	3	5	15
R5	Brakuje śladu: kto zatwierdził i co wysłano	4	3	12

P = prawdopodobieństwo, W = wpływ. Skala 1–5. Wynik 15–25 wymaga redukcji ryzyka przed pilotażem.

Źródło: opracowanie własne.

26

Mapa ryzyka przed wdrożeniem zabezpieczeń



Wniosek

Agent nie powinien przejść do pilotażu w proponowanej konfiguracji. Najpierw trzeba ograniczyć autonomię i uprawnienia oraz oddzielić niezaufaną treść od instrukcji.

DECYZJA: STOP WARUNKOWY

Źródło: opracowanie własne.

Kontrole, które zmieniają decyzję

01 E-mail jako dane

Treść i załączniki nigdy nie stają się instrukcją dla agenta.

03 Człowiek przed wysłaniem

Podgląd ceny, odbiorcy, załączników i podstaw odpowiedzi.

05 Pełne logowanie

Wersja modelu, źródła, wywołania narzędzi, wynik i akceptacja.

02 Minimalne uprawnienia

CRM i cennik tylko do odczytu, z filtrem na konkretny rekord.

04 Twarde reguły

Rabaty i warunki pochodzą z reguły biznesowej, nie z generacji modelu.

06 Bezpiecznik

Limit etap i kosztu, alarerty, przerwanie, rollback i szybkie wyłączenie.

Decyzja: ograniczony pilotaż

TAK, POD WARUNKAMI

Zakres pilotażu

- jedna skrzynka i jeden proces
- CRM tylko do odczytu
- **brak automatycznej wysyłki**
- dane testowe, potem mała grupa klientów
- codzienny przegląd błędów i kosztu
- ponowna decyzja po czterech tygodniach

Ryzyko rezydualne

R1	20 → 8
R2	15 → 5
R3	16 → 6
R4	15 → 5
R5	12 → 3

Punktacja po wdrożeniu i przetestowaniu kontroli

Pierwsze 90 dni

0–30

Obserwacja

- ankieta bez sankcji
- monitorowanie narzędzi i ruchu
- lista procesów krytycznych

31–60

Ustalenie zasad

- progi ryzyka i właściciele
- krótka polityka użycia
- szybka ścieżka zgłoszeń

61–90

Weryfikacja w praktyce

- 2–3 kontrolowane pilotaże
- testy i obserwowalność
- przegląd decyzji oraz wyjątków

Celem pierwszych 90 dni jest widoczność i zdolność podejmowania decyzji, nie perfekcyjna dokumentacja.

Jeśli nie widzisz AI, to nie znaczy, że go nie ma

Stale poszukuję nowych możliwości i ekscytujących wyzwań. Jeśli chcesz się ze mną skontaktować, proszę, skorzystaj z poniższych kanałów:

Email: info@zalnet.pl

LinkedIn: <https://www.linkedin.com/in/beatazalewa/>

Blog: <https://zalnet.pl/shadow-ai-w-firmie/>

X: <https://x.com/beatazalewa>

GitHub: <https://github.com/beatazalewa/Conferences/>



Quiz 1: gdzie ryzyko rośnie najszybciej?

Który przypadek najbardziej zwiększa ryzyko Shadow AI?

A

Streszczenie publicznego raportu w zatwierdzonym narzędziu

B

Analiza danych syntetycznych w odizolowanym środowisku testowym

C

Agent z dostępem do skrzynki i CRM, który może wysłać wiadomości bez akceptacji

D

Korzystanie z katalogu zatwierdzonych promptów

Quiz 2: od czego zacząć analizę?

Co powinno być pierwszym krokiem przy ocenie wdrożenia agenta AI?

A

Wybór modelu z najwyższym wynikiem benchmarku

B

Automatyczne zablokowanie projektu do czasu pełnego audytu

C

Ustalenie celu, właściciela, danych, uprawnień i skutków błędu

D

Zakup narzędzia DLP przed opisaniem przypadku użycia